

1/28

□

File No.: EXP202213514

RESOLUTION OF TERMINATION OF THE PROCEDURE DUE TO VOLUNTARY PAYMENT

From the procedure initiated by the Spanish Agency for Data Protection and based on the following

BACKGROUND

FIRST: On May 21, 2024, the Director of the Spanish Agency for Data Protection agreed to initiate sanctioning proceedings against ALLIANZ COMPAÑÍA DE SEGUROS Y REASEGUROS, S.A. (hereinafter, the respondent), through the Agreement transcribed below:

<<

File No.: EXP202213514

AGREEMENT TO INITIATE SANCTIONING PROCEDURE

From the actions taken by the Spanish Agency for Data Protection and based on the following

FACTS

FIRST: On October 27, 2022, A.A.A. (hereinafter, the complainant) filed a complaint with the Spanish Agency for Data Protection.

The complaint is directed against ALLIANZ COMPAÑÍA DE SEGUROS Y REASEGUROS, S.A. with NIF A28007748 (hereinafter, the respondent).

The reasons on which the complaint is based are as follows:

The complainant states that on June 1, 2022, they received an email from their ex-partner in which a document related to the automobile policy subscribed by the complainant with the respondent was attached, as well as a report from the General Directorate of Traffic, "extracted from the systems of the insurance company to which access was obtained without authorization."

They add that this documentation was provided in the context of a judicial procedure for the modification of parental measures.

Along with the complaint, they provide a copy of the received email messages, as well as a screenshot related to the data associated with the "Comprehensive Auto" policy as a result of a search on the respondent's website and a screenshot related to a Vehicle Report from the DGT.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

2/28

SECOND: This complaint was filed by the complainant with the AEPD on August 8, 2022, giving rise to file EXP202210372. In the context of the aforementioned file, on October 4, 2022, the complainant was informed that their registered complaint had not been admitted for processing, IT/06061/202.

THIRD: On October 27, 2022, the complainant reiterated the complaint filed on August 8, 2022, file EXP202210372, leading to the opening of a new file, the current file EXP202213514. In the context of the current file, the complainant was informed that their complaint filed on October 27, 2022, had not been admitted for processing, IT/08015/2022.

FOURTH: On January 18, 2023, the complainant filed a motion for reconsideration against the resolution of the Spanish Agency for Data Protection (hereinafter, AEPD or Agency) issued on December 20, 2022. On March 31, 2023, in procedure RR/00030/2023, the AEPD agreed to uphold the motion for reconsideration filed, admit the complaint for processing in accordance with the provisions of Article 65 of the LOPDGDD, AT/01642/2023, and carry out the preliminary investigative actions AI/00109/2023 regarding the facts reproduced above.

FIFTH: The General Sub-Directorate for Data Inspection proceeded to carry out preliminary investigative actions to clarify the facts in question, by virtue of the functions assigned to control authorities in Article 57.1 and the powers granted in Article 58.1 of Regulation (EU) 2016/679 (General Data Protection Regulation, hereinafter GDPR), and in accordance with the provisions of Title VII, Chapter I, Section two, of the LOPDGDD.

SIXTH: On January 24, 2024, the director agreed to declare the expiration of the preliminary investigative actions AI/00109/2023, open new investigative actions, AI/00063/2024, and incorporate into these new actions the documentation that integrates the actions declared expired.

SEVENTH: The General Sub-Directorate for Data Inspection concluded its investigative actions AI/00063/2024 on March 19, 2024, through which it became aware of the following points:

-1-. Regarding the evidence provided in the complaints.

The complainant has submitted two complaints, both for the same facts, the first dated August 8, 2022, -file EXP202210372-, and the second dated December 20, 2022, which gives rise to the current file EXP202213514.

The complainant provides, along with their complaint against the respondent, email messages sent to the complainant by their ex-partner dated June 1, 2022, in which their ex-partner attaches two screenshots:

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
3/28

(a) Screenshot of the data related to the policy subscribed between the claiming party and the claimed party.

(b) Report from the General Directorate of Traffic.

Analyzing these annexes, the following information is extracted:

(a) Policy ***POLIZA.1

Policyholder: A.A.A.

This screenshot includes the personal data of the insured policyholder and is presumably a screenshot from the internal client management application of the claimed party.

(b) DGT report of the vehicle ***MATRICULA.1: Report dated 30/05/2022

Owner data: B.B.B.

Vehicle ID: License plate, make, chassis, etc.

Insurance data: Allianz

The report includes (i) the history of owners along with information on start date/end date/type of insurance and (ii) the history of ITV inspections.

The person requesting the report is C.C.C. with date 30/05/2022 and through the Internet Channel. Upon searching for information about this person on the internet, it is revealed that there is a lawyer with that name specializing in divorces based in A Coruña.

On July 19, 2023, the electronic headquarters of the General Directorate of Traffic is consulted regarding the request for vehicle reports, from which the following information is obtained:

- Annex 1. - VEHICLE REPORT. What do you need to know?

“Except for the case of the report of 'vehicles in my name', for which you need to be the owner of the vehicle or a third party authorized on their behalf to download it, the rest of the reports are available to anyone, whether or not they are the owner of the vehicle.”

- Annex 2. - VEHICLE REPORT. What types of Reports can I obtain?

“Complete report: Includes all administrative information, identification of the owner, municipality where the vehicle is registered, ITV history, mileage, number of owners, encumbrances... as well as technical data, EuroNCAP rating, and maintenance regarding the requested vehicle.”

- Annex 3. - Example of a complete vehicle report.

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es

4/28

Upon consulting the claiming party about the name of their ex-partner's lawyer, it is confirmed that it

matches the name of the person appearing in the annex as the requester of the vehicle report through the internet channel.

Therefore, this evidence was not provided by the claimed party; rather, the report was directly requested by the lawyer of the claiming party's ex-partner at the electronic headquarters of the General Directorate of Traffic, as it is a public report.

On March 6, 2024, a new diligence is recorded in the SIGRID system with the previous information and the update of the links to the electronic headquarters of the General Directorate of Traffic where this report can be obtained:

- <https://sede.dgt.gob.es/es/vehiculos/informacion-de-vehiculos/informe-de-un-vehiculo/>
- <https://sede.dgt.gob.es/export/sites/dgt/.galleries/ayuda/informe-completo.pdf>

.-2-. Regarding the information provided in the responses to the information requests
.-2.A-

On July 24, 2023, an information request is made to the claimed party asking, among other points, for confirmation that the screenshot belongs to the client management program of ALLIANZ and the Protocol for accessing policy data.

The claimed party responds to this information request with a registration date of August 11, 2023, providing the following documentation in their response:

- .- Copy of the policy that proves the ownership of the claiming party during the time the policy was in force.
- .- Quick guide on call quality, which describes the procedure followed by the Company to verify the identity of the person making the call and to ensure that the caller is the policyholder and not a third party.
- .- Diagram of access by users to the various applications that make up the Company's client management program.
- .- Movements produced in the policy of the claiming party.

.-2.B-. With a registration date of September 18, 2023, the claimed party sends this Agency an Additional Document in response to the information request, in which they provide the following documentation in their response:

- .- Written response to the Information Request
- .- Proof of the breach reported by the claimed party to the electronic registry of the AEPD.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

5/28

- .- Code of Conduct of the ALLIANZ Group, mandatory for all employees
- .- Screenshot of the latest training received by the employee responsible for the incident.
- .- 2.C-. On February 1, 2024, a request for information is made to the responding party, requesting, among other points, justification for the necessity of the employee who caused the breach having access permissions to the data of the claiming party and the accreditation of the instructions that ALLIANZ previously communicated to said employee regarding the processing of customer data. The responding party responds to this request for information with a registration date of February 15, 2024, providing the following documentation in its response:
 - .- Registration of Data Protection Delegate with the list of Data Protection Delegates
 - .- Code of Conduct of the ALLIANZ Group, mandatory for all employees
 - .- (Internal) acceptable use policy for assets
 - .- (Internal) information classification policy
 - .- Screenshots of the homepage of the currently available courses on data protection and confidentiality
 - .- History of training conducted by the employee
 - .- Procedure for defining and maintaining roles and access
 - .- ID Certification Management Procedure

- Confirmations by the heads of each Allianz unit regarding the audit and review carried out of each user's permissions
- Report issued by the Allianz Data Protection Delegate on September 13, 2023, regarding the events that caused the breach
- Copy of the Record of Processing Activities where the incident occurred
- Risk analysis for the security of the aforementioned processing activities carried out by Allianz in accordance with Article 32 of the GDPR
- Copy of the information contained in the incident register related to said breach, where it was recorded on July 24, 2023

C/ Jorge Juan, 6
 www.aepd.es
 28001 – Madrid
 sedeagpd.gob.es

6/28

- Screenshot of the homepage of the portal "Data Protection at Allianz and the Allianz Private Community" located within the Allianz Intranet
- Copy of the Standard Privacy Document of the Allianz Group

- 2.1-. Regarding the particular case of the claiming party

- 2.1.1-. Response to the first request for information

The responding party, in its response document, provides the following information and statements:

- Confirms and provides evidence that the policyholder was the claiming party and indicates that said policy is currently not in force as it was requested to be canceled by the policyholder on June 30, 2022, as a result of the sale of the vehicle, and the Company proceeded to cancel said policy effective July 5, 2022;

- Confirms that "the image of the annex included in the requested information corresponds to the 'general inquiries' application of the Company's customer management program"

- Indicates that it does not have access to said policy between the dates of May 31, 2022, and June 2, 2022. "Therefore, we cannot provide you with the requested information as we do not have it."

- Confirms and provides evidence that on June 1, 2022, no modifications were made to said policy;

- Informs that as of the date of submission of the document, it is not aware of any incident or unauthorized access by third parties to the data of the policy, so it does not have any additional information to provide, although it communicates that "the Company has initiated an investigation as a result of your request for information that is still ongoing, and we will inform you of its outcome in due course once it is concluded, in the event that as a result of this investigation we become aware of the existence of any incident or any unauthorized access by third parties."

- 2.1.2-. Expansion of information in response to the first request for information

As a result of the internal investigation initiated due to the request for information, the responding party indicates that the origin of the incident is an employee of the Claims Processing Center (CTS) of the Company (D.D.D.) "who, in violation of the Company's data protection policies and the code of conduct applicable to all employees of the Company that includes the confidentiality duty that all employees have concerning customer data."

C/ Jorge Juan, 6
 www.aepd.es
 28001 – Madrid
 sedeagpd.gob.es

7/28

personal character to which they may access for the exercise of their functions, proceeded in June 2022 to capture an image of the information contained in the "general inquiries" application of the customer management program of the Company of the policy that corresponds to the image for which confirmation was requested from the Company in the Information Request, which corresponded to its customer management program, and proceeded to provide it to the ex-wife of the policyholder with whom the aforementioned employee maintained a friendship so that she could prove that her

ex-husband was the holder of said Policy in the context of the existing divorce judicial procedure between the policyholder and the ex-wife. This unauthorized communication, which was carried out by the employee intentionally and knowingly of its unlawfulness, constitutes a breach of the confidentiality of personal data that the Company has proceeded to communicate on September 14 within the seventy-two (72) hours from the moment it became aware of it established by current regulations. (Note: the underlining has been added by the Agency)

The responding party provides the Company's Code of Conduct, which is mandatory for all employees, where the duty of confidentiality is reflected; and a screenshot of the latest training received by the employee responsible for the incident regarding data protection.

ALLIANZ communicates that, "in light of the conduct carried out by the aforementioned employee which constitutes a flagrant breach of the duty of confidentiality," it has proceeded "to inform the Company's Integrity Committee of these facts so that, following the established internal procedures, it decides on the actions (including, where appropriate, disciplinary actions) to be taken against the employee in light of such a flagrant breach."

.-2.1.3-. Regarding the necessity of the employee to access the data in the exercise of her functions Upon reviewing the document, the access diagram for users to the various applications that make up the Company's customer management program (see section 2.2 of this report) and the response letter, it is confirmed that the employee responsible for the incident was authorized to access the data for the development of her functions as she belongs to the Claims Processing Center (CTS) of ALLIANZ.

.-2.1.4-. Regarding the instructions communicated to the employee that caused the breach concerning the processing of customer data

The responding party specifies in its response letter the codes and internal regulations, applicable to all employees of the Company, that outline the instructions to ensure the confidentiality of their clients' personal data (see section 2.4 of this report) and provides as evidence the history of the training conducted by the employee.

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
8/28

.-2.1.5-. Regarding the technical reports or recommendations prepared by the Data Protection Officer concerning the incident that occurred

In its response, the responding party provides the report issued by the Data Protection Officer of Allianz dated September 13, 2023, regarding the facts that caused the breach, its consequences for the claimant, the actions taken to resolve it, including the analysis on the necessity to communicate it to the supervisory authority (communication that was made on September 14, 2023) and, if applicable, to the claimant, as well as on the sufficiency of the existing controls to prevent future similar breaches. It is noted that the Company concludes "that the measures implemented by the Company prior to the incident are sufficient to prevent future similar breaches, being aware that, as recognized by the European Data Protection Board in case no. 8 of its Guide 1/2021 on examples related to the communication of data breaches adopted on January 14, 2021, this type of breach is the most difficult to prevent by data controllers."

Additionally, it provides a copy of the information recorded in the incident log regarding this breach, where it was registered on July 24, 2023.

.-2.2-. Regarding the protocol for accessing policy data

The responding party, in its response, provides the following information and statements:

.- It indicates that "the policyholders of our policies can access the data contained in their policies through their broker, through the e-client mobile application, by calling the Company's customer service, as well as physically through the various offices that the Company has open throughout Spanish territory." ALLIANZ attaches a quick guide on call quality, which describes the procedure followed by the Company to verify the identity of the person making the call and to ensure that the caller is the policyholder and not a third party.

.- It informs that, regarding the Company's personnel, only those individuals who need access to the

policy data for the performance of their functions have access to the data of their insured clients, and, in general, the personnel of the Customer Service (SAC), the Business Support Office (OSN), the Claims Processing Center (CTS), the central services of the Company, as well as the sales network and branches of the Company, although in this case, agents and brokers only have access to the policy data for which they are registered as mediators and that constitute their portfolio, indicating the different types of user profiles of the "general inquiries" application of the Company's customer management program. It provides a diagram of access by users to the various applications that make up the Company's customer management program.

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
9/28

.-2.3-. Regarding the measures implemented by the Company to prevent similar incidents

Once the incident that prompted the claim became known, the responding party indicates in its written response the measures implemented to prevent an employee from communicating personal data for which the Company is responsible to unauthorized third parties outside the Company, and to which access is necessary for the performance of their functions:

“(…)”

ALLIANZ states that it has taken the opportunity to accelerate and promote the following measure that it had planned to carry out, consisting of sending all employees of the Company a catalog of the main risk behaviors regarding data protection that are prohibited by the Company, which will include the present case.

The responding party provides a copy of the Record of Processing Activities where the incident occurred, in accordance with Article 30 of the GDPR; and a Risk Analysis for the security of the aforementioned processing activities carried out by ALLIANZ in accordance with Article 32 of the GDPR.

.-2.4-. Regarding the specific instructions given by the Company to its employees in order to ensure the confidentiality of personal data of its clients

In its written response, the responding party indicates the internal codes and standards applicable to all employees of the Company, which outline the instructions to ensure the confidentiality of personal data of its clients:

.- The ALLIANZ Group Code of Conduct, which includes in its section “Responsible Data Management” the confidentiality commitment that employees have regarding personal data they may access in the performance of their functions and expressly establishes the prohibition of sharing such data with unauthorized third parties.

.- The internal acceptable use policy for assets, which establishes in its sections 5.1 and 5.2 the obligation of ALLIANZ employees to use responsibly, maintain professional secrecy, and uphold maximum confidentiality, as well as establishing the duty not to disclose or use directly or through third parties, personal data in accordance with the GDPR that they access in the performance of their functions.

.- The internal information classification policy, which expressly establishes in its section 5.1 the obligation of all Allianz employees not to disclose or reveal classified information with the levels of Confidential or Strictly Confidential to any other user (employee or third party), unless explicitly authorized by the asset owner or necessary for the performance of their functions.

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es

10/28

The responding party continues to explain that “the internal regulations are complemented by the training plan on data protection and confidentiality designed by the Company for all its employees,

which includes a series of courses related to this matter,” and provides screenshots of the homepage of the courses currently available on data protection and confidentiality.

.-2.5-. Regarding the audits that ALLIANZ conducts periodically on the accesses made by its employees, to monitor access and detect behaviors that may be suspicious

The responding party indicates in its written response that “it has a Procedure for defining and maintaining roles and accesses, for determining the roles and accesses of users in the Company’s assets, in order to ensure the protection of information assets and their confidentiality, basing access to such information on the legitimate need of users for the performance of their professional activity. (...).”

In this regard, it provides the documents: Procedure for defining and maintaining roles and accesses; ID Certification Management Procedure; and Confirmations by the heads of each unit of Allianz in the context of the audit and review carried out of each user’s permissions.

EIGHTH: The AEPD has had access to the annual accounts audit report issued on March 30, 2023, by an independent auditor, which has provided the Uniform Resource Locator, that is, the following URL, ***URL.1

This document allows determining the business volume of the responding party, using the figure from the indicator “Earned premiums – direct insurance.” However, as its accounts are divided into “non-life” and “life,” both must be summed:

- “non-life,” earned premiums direct insurance: 2,236,771 thousand euros (page 19)

- “life,” earned premiums direct insurance: 367,249 thousand euros (page 21).

Therefore, from this document, it can be inferred that as of December 2022, the business volume of the responding party reached the amount of 2,604,020 thousand euros.

LEGAL GROUNDS

I

Competence

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

11/28

In accordance with the powers granted to each supervisory authority by Article 58.2 of Regulation (EU) 2016/679 (General Data Protection Regulation, hereinafter GDPR), and as established in Articles 47, 48.1, 64.2, and 68.1 of Organic Law 3/2018, of December 5, on the Protection of Personal Data and Guarantee of Digital Rights (hereinafter, LOPDGDD), the Director of the Spanish Agency for Data Protection is competent to initiate and resolve this procedure.

Furthermore, Article 63.2 of the LOPDGDD states: “The procedures processed by the Spanish Agency for Data Protection shall be governed by the provisions of Regulation (EU) 2016/679, this organic law, the regulatory provisions issued in its development, and, insofar as they do not contradict them, subsidiarily by the general rules on administrative procedures.”

II

Preliminary Issues

In this case, we are faced with a complaint filed due to the leakage of personal data of the complainant consisting of policy number, vehicle registration, as well as the name and surname of the complainant. The complainant provides two screenshots as evidence of the information leak.

The complainant alleges that their ex-partner has accessed their insurance data.

The respondent acknowledges that the personal data of the complainant was extracted and leaked by one of its employees, who passed it on to the complainant’s ex-partner.

However, the respondent claims that this employee, a claims handler for the company ALLIANZ, that is, the respondent, was authorized by her functions to access the policies of the clients, among whom is the complainant.

The respondent acknowledges that there is no traceability of accesses, and from this lack of traceability, a lack of security measures is inferred.

It should be noted that traceability is an instrument that precisely allows for the control of the possibility of unauthorized access, regardless of whether there are profiles in place.

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es

12/28

Moreover, in this case, a screenshot of the application has been extracted, despite the existence of applications that prevent screenshots from being taken to avoid possible information leakage. It has been confirmed that the first piece of evidence is a screenshot from the internal client management application of the respondent, and the second piece of evidence is a screenshot of the public report that can be obtained through the electronic headquarters of the General Directorate of Traffic.

The respondent has initiated an internal investigation as a result of the information request and, as a result, has communicated that the origin of the incident was an employee of the Claims Processing Center (CTS) of the Company (D.D.D.) who, in June 2022, took a screenshot of the information contained in the "general inquiries" application of the client management program of the Company regarding the complainant's policy and proceeded to provide it to the ex-wife of the policyholder, with whom the aforementioned employee maintained a friendship.

The investigative actions have confirmed that the employee responsible for the incident was authorized to access the data for the performance of her duties as she belonged to the Claims Processing Center (CTS) of ALLIANZ.

Through these investigative actions, it has been evidenced that the respondent provided instructions on the processing of client data to all employees of the company, particularly to the employee who caused the security breach, as the respondent has provided the history of the training sessions conducted for the employee regarding data protection and confidentiality.

Additionally, through the prior investigation conducted, it has been verified that the Data Protection Officer prepared a report regarding the incident that occurred, concluding the necessity to communicate the confidentiality breach to the supervisory authority (communicated on September 14, 2023).

Furthermore, the respondent has provided the protocol for accessing policy data for both policyholders (providing a document that describes the procedure followed by the Company to verify the identity of the person) and for the personnel of the respondent.

Finally, the respondent has detailed the measures implemented by the Company to prevent similar incidents from occurring, thus providing evidence of the audits conducted annually regarding the management of identity certification.

III

Article 5.1.f) of the GDPR

Article 5.1.f) of the GDPR establishes the following:

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es

13/28

"Article 5 Principles relating to processing:

1.

Personal data shall be:

(...)

f) processed in a manner that ensures appropriate security of personal data, including protection against unauthorized or unlawful processing and against accidental loss, destruction, or damage, by means of appropriate technical or organizational measures ("integrity and confidentiality")."

In relation to this principle, Recital 39 of the aforementioned GDPR states:

"[...] Personal data must be processed in a manner that ensures adequate security and confidentiality of personal data, including to prevent unauthorized access or use of such data and the equipment used for processing."

Article 5.1 f) of the GDPR establishes the means through which the maintenance of confidentiality and integrity must be achieved when it specifies "by means of appropriate technical and organizational measures," which are not strictly security measures.

The complainant has reported to the AEPD that their ex-partner has accessed the data contained in the insurance policy contracted with the respondent.

The respondent has acknowledged that the personal data of the complainant were extracted and leaked by one of its employees, a claims handler, and provided to the complainant's ex-partner.

The respondent justifies itself by indicating that its employee must have access to the personal data of the complainant to perform their duties.

Neither the aforementioned statement nor the alleged friendship between the employee of the respondent company and the complainant's ex-partner to whom the data were transferred justifies or legitimizes the reported facts, namely, that access to the personal data of the complainant was granted to their ex-partner without their consent.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

14/28

In accordance with the evidence currently available, and without prejudice to what results from the investigation, it could be considered that the reported facts, consisting of an employee of the respondent entity granting access to the personal data of the complainant to a third party without the consent of the data subject, could imply that the respondent, as the ultimate responsible party for the processing of the personal data of the complainant, has violated the confidentiality required by personal data protection regulations, due to lacking the appropriate technical and organizational measures in the processing of the personal data for which it is responsible.

Therefore, there are clear indications of processing contrary to personal data protection regulations by the respondent entity, as Article 5.1 f) of the GDPR would have been violated, a provision that establishes the principle of integrity and confidentiality in the processing of personal data.

IV

Classification of the infringement of Article 5.1.f) of the GDPR

If confirmed, the aforementioned infringement of Article 5.1.f) of the GDPR could imply the commission of the infringements classified in Article 83.5 of the GDPR, which under the heading "General conditions for the imposition of administrative fines" provides:

"Violations of the following provisions shall be sanctioned, in accordance with paragraph 2, with administrative fines of up to 20,000,000 EUR or, in the case of an enterprise, an amount equivalent to 4% of the total annual global turnover of the previous financial year, opting for the higher amount:

a) the basic principles for processing, including the conditions for consent under Articles 5, 6, 7, and 9; (...)"

In this regard, the LOPDGDD, in its Article 71 "Infringements" establishes that "Acts and behaviors referred to in paragraphs 4, 5, and 6 of Article 83 of Regulation (EU) 2016/679, as well as those that are contrary to this organic law, constitute infringements."

For the purposes of the statute of limitations, Article 72 "Very serious infringements" of the LOPDGDD indicates:

"1. In accordance with what is established in Article 83.5 of Regulation (EU) 2016/679, the following shall be considered very serious and shall prescribe after three years: infringements that constitute a substantial violation of the articles mentioned therein and, in particular, the following:

C/ Jorge Juan, 6

www.aepd.es

a)

The processing of personal data violating the principles and guarantees established in Article 5 of Regulation (EU) 2016/679. (...)

V

Sanction of Article 5.1f) of the GDPR

In order to determine the administrative fine to be imposed, the provisions of Articles 83.1 and 83.2 of the GDPR must be observed, which state:

“1. Each supervisory authority shall ensure that the imposition of administrative fines under this article for the infringements of this Regulation indicated in paragraphs 4, 5, and 6 are, in each individual case, effective, proportionate, and dissuasive.

2. Administrative fines shall be imposed, depending on the circumstances of each individual case, as an additional or substitute measure to those provided for in Article 58, paragraph 2, letters a) to h) and j). In deciding on the imposition of an administrative fine and its amount in each individual case, the following shall be duly taken into account:

- a) the nature, gravity, and duration of the infringement, taking into account the nature, scope, or purpose of the processing operation in question, as well as the number of data subjects affected and the level of damage and detriment suffered;
- b) the intentionality or negligence in the infringement;
- c) any measures taken by the controller or processor to mitigate the damage and detriment suffered by the data subjects;
- d) the degree of responsibility of the controller or processor, taking into account the technical or organizational measures they have implemented pursuant to Articles 25 and 32;
- e) any previous infringement committed by the controller or processor;
- f) the degree of cooperation with the supervisory authority in order to remedy the infringement and mitigate the possible adverse effects of the infringement;
- g) the categories of personal data affected by the infringement;
- h) the manner in which the supervisory authority became aware of the infringement, in particular whether the controller or processor notified the infringement and, if so, to what extent;
- i) when the measures indicated in Article 58, paragraph 2, have been previously ordered against the controller or processor in relation to the same matter, the compliance with such measures;
- j) adherence to codes of conduct under Article 40 or to certification mechanisms approved under Article 42,
- k) any other aggravating or mitigating factor applicable to the circumstances of the case, such as the financial benefits obtained or the losses avoided, directly or indirectly, through the infringement.”

For its part, Article 76 “Sanctions and corrective measures” of the LOPDGDD provides:

“1. The sanctions provided for in paragraphs 4, 5, and 6 of Article 83 of Regulation (EU) 2016/679 shall be applied taking into account the criteria for graduation established in paragraph 2 of the aforementioned article.

2. In accordance with the provisions of Article 83.2.k) of Regulation (EU) 2016/679, the following may also be taken into account:

- a) The continued nature of the infringement.
- b) The connection of the infringer's activity with the processing of personal data.
- c) The benefits obtained as a result of the commission of the infringement.
- d) The possibility that the conduct of the affected party may have induced the commission of the infringement.
- e) The existence of a merger by absorption after the commission of the infringement, which cannot be attributed to the absorbing entity.
- f) The impact on the rights of minors.
- g) Having, when not mandatory, a data protection officer.
- h) The voluntary submission by the controller or processor to alternative dispute resolution

mechanisms, in cases where there are disputes between them and any data subject.”

In accordance with the transcribed provisions, and without prejudice to the outcome of the instruction of the procedure, for the purpose of setting the amount of each sanction for each infringement, each fine is graduated taking into account:

As aggravating factors:

Article 83.2 e) GDPR: “any previous infringement committed.” On May 10, 2021, a fine of 30,000 euros (thirty thousand euros) was imposed on the respondent for carrying out an unlawful processing of personal data, in PS/00123/2021.

Article 76.2 b) LOPDGDD: “The connection of the infringer’s activity with the processing of personal data.” The activity of the respondent entity requires continuous processing of personal data.

Furthermore, the entity

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

17/28

The respondent carries out a high volume of personal data processing for the development of its activity.

Considering the factors presented, the initial assessment of the fine amounts to €140,000 for the infringement of Article 5.1(f) of the GDPR, regarding the violation of the principle of confidentiality.

VI

Article 32 of the GDPR

Article 32 of the GDPR establishes the following regarding the security of processing:

“1. Taking into account the state of the art, the costs of implementation, and the nature, scope, context, and purposes of the processing, as well as the varying likelihood and severity of risks to the rights and freedoms of natural persons, the controller and the processor shall implement appropriate technical and organizational measures to ensure a level of security appropriate to the risk, which may include, among others:

- a) the pseudonymization and encryption of personal data;
- b) the ability to ensure the ongoing confidentiality, integrity, availability, and resilience of processing systems and services;
- c) the ability to restore the availability and access to personal data quickly in the event of a physical or technical incident;
- d) a process for regularly verifying, assessing, and evaluating the effectiveness of the technical and organizational measures to ensure the security of processing.

2. In assessing the appropriateness of the level of security, particular consideration shall be given to the risks presented by the processing of data, in particular as a result of the accidental or unlawful destruction, loss, or alteration of personal data transmitted, stored, or otherwise processed, or the unauthorized communication or access to such data.

3. Adherence to an approved code of conduct pursuant to Article 40 or to an approved certification mechanism pursuant to Article 42 may serve as an element to demonstrate compliance with the requirements set out in paragraph 1 of this Article.

4. The controller and the processor shall take measures to ensure that any person acting under the authority of the controller or the processor and having access to personal data only processes such data on instructions from the controller, unless he or she is required to do so by Union or Member State law.”

It should be noted that the GDPR in the cited provision does not establish a list of security measures applicable according to the data being processed, but rather states that the controller and the processor shall implement technical and organizational measures that are appropriate to the risk posed by the processing, taking into account the state of the art, the costs of implementation, the nature, scope, context, and purposes of the processing, and the likelihood and severity of risks to the rights and freedoms of data subjects.

Furthermore, the security measures must be adequate and proportionate to the identified risk, indicating that the determination of technical and organizational measures must be made taking into account: pseudonymization and encryption, the ability to ensure confidentiality, integrity, availability, and resilience, the ability to restore availability and access to data following an incident, and a process of verification (which is not an audit), assessment, and evaluation of the effectiveness of the measures. In any case, when assessing the appropriateness of the level of security, particular consideration shall be given to the risks posed by the processing of data, as a result of the accidental or unlawful destruction, loss, or alteration of personal data transmitted, stored, or otherwise processed, or the unauthorized communication or access to such data that could cause physical, material, or immaterial damage.

In this same sense, Recital 83 of the GDPR states:

“(83) In order to maintain security and prevent processing from infringing the provisions of this Regulation, the controller or the processor must assess the risks inherent in the processing and implement measures to mitigate them, such as encryption. These measures must ensure an adequate level of security, including confidentiality, taking into account the state of the art and the cost of their implementation in relation to the risks and the nature of the personal data that must be protected. When assessing the risk in relation to data security, the risks arising from the processing of personal data must be taken into account, such as the accidental or unlawful destruction, loss, or alteration of personal data transmitted, stored, or otherwise processed, or the unauthorized communication or access to such data, which could in particular cause physical, material, or immaterial damage.”

The responsibility of the respondent is determined by the lack of security measures adopted, with the peculiarities it presents, as it is responsible for making decisions aimed at effectively implementing appropriate technical and organizational measures to ensure a level of security adequate to the risk to ensure the confidentiality of the data, restoring its availability and preventing access to it in the event of a physical or technical incident.

Therefore, this Agency considers that Article 32 of the GDPR may also have been violated, as the respondent entity did not comply with the requirements set forth.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

19/28

obligation to implement appropriate technical and organizational security measures to ensure in this specific case.

To assess the scope of such facts, which are the focus of this sanctioning procedure, it must be taken into account that traceability is a tool that allows for the control of the possibility of unauthorized access.

The responding party states that, regarding the Company's personnel, only those individuals who need access to the policy data of their insured clients for the performance of their duties have such access, and, in general, the personnel of the Customer Service (SAC), the Business Support Office (OSN), the Claims Processing Center (CTS), the central services of the Company, as well as the sales network and branches of the Company, although in this case, agents and brokers only have access to the policy data for which they are registered as mediators and that constitute their portfolio, indicating the different types of user profiles of the "general inquiries" application of the Company's customer management program. It provides a diagram of user access to the various applications that make up the Company's customer management program.

It also points out that once the incident that prompted the complaint was known, it took the opportunity to expedite and promote a measure that it had planned to carry out, consisting of sending all employees of the Company a catalog of the main risk behaviors regarding data protection that are prohibited by the Company, which will

include the present case.

The responding party provides the codes and internal regulations applicable to all employees of the Company, which contain instructions to ensure the confidentiality of the personal data of its clients:

The responding party continues to explain that "the internal regulations are supplemented by the training plan on data protection and confidentiality designed by the Company for all its employees, which includes a series of courses related to this subject," and provides screenshots of the home screen of the courses currently available on data protection and confidentiality.

The responding party states that "it has a Procedure for defining and maintaining roles and access, for determining the roles and access of users in the Company's assets, in order to ensure the protection of information assets and their confidentiality, basing access to such information on the legitimate need of users for the performance of their professional activity. (...)"

In this regard, the responding party provides the documents, Procedure for defining and maintaining roles and access; ID Certification Management Procedure; and Confirmations by the heads of each Allianz unit regarding the audit and review conducted of each user's permissions.

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
20/28

The AEPD considers that as a result of the preliminary investigation actions, it has been verified that the party being complained against lacked appropriate technical and organizational measures to ensure a level of security adequate to the risk presented by the processing of personal data in an insurance company like that of the party being complained against, since among these risks was the risk of capturing screens with the personal data contained in the policies.

Therefore, given such a risk of unlawful capture, their duty as the data controller of this personal data was to foresee it and adopt "appropriate technical and organizational measures to ensure a level of security adequate to the risk," aimed at preventing any member of the organization from capturing that personal data and transmitting it outside the organization.

Consequently, in accordance with the evidence available at this moment and without prejudice to what results from the instruction, it is considered that the known facts could constitute an infringement attributable to the party being complained against, for violation of Article 32 of the GDPR.

VII

Classification of the infringement of Article 32 of the GDPR

If confirmed, the aforementioned infringement of Article 32 of the GDPR could imply the commission of the infringements classified in Article 83.4 of the GDPR, which under the heading "General conditions for the imposition of administrative fines" states:

"Violations of the following provisions shall be sanctioned, in accordance with paragraph 2, with administrative fines of up to 10,000,000 EUR or, in the case of an enterprise, an amount equivalent to a maximum of 2% of the total annual global turnover of the previous financial year, opting for the higher amount:

a) the obligations of the controller and the processor under Articles 8, 11, 25 to 39, 42, and 43; (...)"

In this regard, the LOPDGDD, in its Article 71 "Infringements" establishes that "Acts and behaviors referred to in paragraphs 4, 5, and 6 of Article 83 of Regulation (EU) 2016/679, as well as those that are contrary to this organic law, constitute infringements."

For the purposes of the statute of limitations, Article 73 "Infringements considered serious" of the LOPDGDD indicates:

"Based on what is established in Article 83.4 of Regulation (EU) 2016/679, the following shall be considered serious and shall be subject to a two-year statute of limitations: infringements that

constitute a substantial violation of the articles mentioned therein and, in particular, the following:

f) The failure to adopt those technical and organizational measures that are appropriate to ensure a level of security adequate to the risk of processing, in the terms required by Article 32.1 of Regulation (EU) 2016/679."

VIII

Sanction of Article 32 of the GDPR

In order to determine the administrative fine to be imposed, the provisions of Articles 83.1 and 83.2 of the GDPR must be observed, which state:

"1. Each supervisory authority shall ensure that the imposition of administrative fines under this article for the infringements of this Regulation indicated in paragraphs 4, 5, and 6 is, in each individual case, effective, proportionate, and dissuasive.

2. Administrative fines shall be imposed, depending on the circumstances of each individual case, as an additional or substitute measure to those provided for in Article 58, paragraph 2, letters a) to h) and j). In deciding on the imposition of an administrative fine and its amount in each individual case, the following shall be duly taken into account:

- a) the nature, gravity, and duration of the infringement, taking into account the nature, scope, or purpose of the processing operation in question, as well as the number of data subjects affected and the level of damage and detriment suffered;
- b) the intentionality or negligence in the infringement;
- c) any measures taken by the controller or processor to mitigate the damage and detriment suffered by the data subjects;
- d) the degree of responsibility of the controller or processor, taking into account the technical or organizational measures they have implemented under Articles 25 and 32;
- e) any previous infringement committed by the controller or processor;
- f) the degree of cooperation with the supervisory authority in order to remedy the infringement and mitigate the possible adverse effects of the infringement;
- g) the categories of personal data affected by the infringement;
- h) the manner in which the supervisory authority became aware of the infringement, in particular whether the controller or processor notified the infringement and, if so, to what extent;
- i) when the measures referred to in Article 58, paragraph 2, have previously been ordered against the controller or processor in relation to the same matter, compliance with those measures;
- j) adherence to codes of conduct under Article 40 or to certification mechanisms approved under Article 42,

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

22/28

k) any other aggravating or mitigating factor applicable to the circumstances of the case, such as the financial benefits obtained or the losses avoided, directly or indirectly, through the infringement."

For its part, Article 76 "Sanctions and corrective measures" of the LOPDGDD states:

"1. The sanctions provided for in paragraphs 4, 5, and 6 of Article 83 of Regulation (EU) 2016/679 shall be applied taking into account the criteria for graduation established in paragraph 2 of the aforementioned article.

2. In accordance with the provisions of Article 83.2.k) of Regulation (EU) 2016/679, the following may also be taken into account:

- a) The continued nature of the infringement.
- b) The link between the infringer's activity and the processing of personal data.
- c) The benefits obtained as a result of the commission of the infringement.
- d) The possibility that the conduct of the affected party may have induced the commission of the infringement.
- e) The existence of a merger by absorption after the commission of the infringement, which cannot be

attributed to the absorbing entity.

f) The impact on the rights of minors.

g) Having, when not mandatory, a data protection officer.

h) The voluntary submission by the responsible party or processor to alternative dispute resolution mechanisms, in cases where there are disputes between them and any interested party.”

In accordance with the transcribed provisions, and without prejudice to the outcome of the instruction of the procedure, for the purpose of determining the amount of each sanction for each infringement, each fine is graduated taking into account:

As aggravating factors:

Article 83.2 e) GDPR: “any previous infringement committed.” On May 10, 2021, a sanction of 30,000 euros (thirty thousand euros) was imposed on the complained party for carrying out an unlawful processing of personal data, in PS/00123/2021.

Article 76.2 b) LOPDGDD: “The link between the infringer's activity and the processing of personal data.” The activity of the complained entity requires continuous processing of personal data.

Furthermore, the complained entity carries out a high volume of personal data processing for the development of its activity.

Considering the factors presented, the initial assessment of the amount of the fine is 60,000 € for the infringement of Article 32 of the GDPR, regarding the security of personal data processing.

IX

Responsibility

Law 40/2015, of October 1, on the Legal Regime of the Public Sector, establishes in Chapter III relating to the “Principles of the Sanctioning Power,” in Article 28 under the heading “Responsibility,” the following:

“1. Only individuals and legal entities, as well as, when a law recognizes their capacity to act, groups of affected parties, unions, and entities without legal personality and independent or autonomous assets, may be sanctioned for acts constituting an administrative infringement, which are responsible for the same by way of intent or negligence.”

The lack of diligence in implementing appropriate security measures resulting in a breach of the principle of confidentiality constitutes the element of culpability.

X

Measures

If both infringements are confirmed, it could be agreed to impose on the responsible party the adoption of appropriate measures to adjust their actions to the regulations mentioned in this act, in accordance with the provisions of the aforementioned Article 58.2 d) of the GDPR, according to which each supervisory authority may “order the controller or processor to ensure that the processing operations comply with the provisions of this Regulation, where appropriate, in a specific manner and within a specified time frame...”. The imposition of this measure is compatible with the sanction consisting of an administrative fine, as provided in Article 83.2 of the GDPR.

Specifically, in this case, the measures would consist of notifying within three months from the receipt of the resolution issued, that the entity responsible for the processing of personal data complies with the provisions of this Regulation, ensuring the principle of integrity and confidentiality of the personal data processed, in accordance with Article 5.1 f) of the GDPR, the adoption of appropriate technical and organizational measures to ensure the traceability of access to the personal data of its clients, to guarantee confidentiality, integrity, availability, and resilience, as well as the ability to restore availability and access to personal data after an incident such as the one at hand, as well as having an adequate process for verifying, evaluating, and assessing the effectiveness of such measures, in accordance with Article 32 of the GDPR.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

24/28

It is warned that failure to comply with the requirements of this body may be considered an

administrative infraction in accordance with the provisions of the GDPR, classified as an infraction in its articles 83.5 and 83.6, which may lead to the initiation of further administrative sanctioning procedures.

Therefore, in light of the above, by the Director of the Spanish Agency for Data Protection,
IT IS AGREED:

FIRST: TO INITIATE SANCTIONING PROCEDURE against ALLIANZ COMPAÑÍA DE SEGUROS Y REASEGUROS, S.A., with NIF A28007748, for the alleged infraction of [for the alleged infractions of articles 5.1. f) and 32 of the GDPR, classified in accordance with the provisions of article 83.5 of the GDPR, regarding the infraction of article 5.1 f) of the GDPR classified as very serious and for prescription purposes in article 72.1 a) of the LOPDGDD, and in accordance with article 83.4 of the GDPR, regarding the infraction of article 32 of the GDPR classified as serious and for prescription purposes in articles 73 f) of the LOPDGDD.

SECOND: TO APPOINT R.R.R. as instructor and S.S.S. as secretary, indicating that either of them may be challenged, if applicable, in accordance with the provisions of articles 23 and 24 of Law 40/2015, of October 1, on the Legal Regime of the Public Sector (LRJSP).

THIRD: TO INCORPORATE into the sanctioning file, for evidentiary purposes, the complaint filed by the claimant and its documentation, as well as the documents obtained and generated by the General Subdirectorate of Data Inspection in the proceedings prior to the initiation of this sanctioning procedure.

FOURTH: THAT for the purposes provided in article 64.2 b) of Law 39/2015, of October 1, on the Common Administrative Procedure of Public Administrations, the sanction that may correspond would be €140,000 (one hundred forty thousand euros) for the infraction of article 5.1 f) of the GDPR, regarding the violation of the principle of confidentiality, and €60,000 (sixty thousand euros) for the infraction of article 32 of the aforementioned GDPR, regarding the security of the processing of personal data, without prejudice to what results from the instruction, which amounts to a total fine of €200,000 (two hundred thousand euros).

FIFTH: TO NOTIFY this agreement to ALLIANZ COMPAÑÍA DE SEGUROS Y REASEGUROS, S.A., with NIF A28007748, granting a hearing period of ten working days for it to formulate allegations and present any evidence it deems appropriate. In its written allegations, it must provide its NIF and the file number that appears in the heading of this document.

If no allegations are made regarding this initiation agreement within the stipulated period, it may be considered a proposal for resolution, as established in article 64.2.f) of Law 39/2015, of October 1, on the Common Administrative Procedure of Public Administrations (hereinafter, LPACAP).

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

25/28

In accordance with the provisions of Article 85 of the LPACAP, you may acknowledge your responsibility within the period granted for the submission of allegations to this initiation agreement; this will entail a reduction of 20% of the sanction that may be imposed in this procedure. With the application of this reduction, the sanction would be set at 160,000 euros, concluding the procedure with the imposition of this sanction.

Similarly, you may, at any time prior to the resolution of this procedure, voluntarily pay the proposed sanction, which will result in a 20% reduction of its amount. With the application of this reduction, the sanction would be set at [Insert the corresponding text of 160,000 euros and its payment will imply the termination of the procedure, without prejudice to the imposition of the corresponding measures.

The reduction for the voluntary payment of the sanction is cumulative with the one applicable for the acknowledgment of responsibility, provided that this acknowledgment of responsibility is made within the period granted to submit allegations to the opening of the procedure. The voluntary payment of the amount referred to in the previous paragraph may be made at any time prior to the resolution. In this case, if both reductions were applicable, the amount of the sanction would be set at 120,000 euros. In any case, the effectiveness of either of the two mentioned reductions will be conditioned upon the

withdrawal or renunciation of any action or appeal in the administrative route against the sanction. In the event that you choose to proceed with the voluntary payment of either of the amounts indicated above, 160,000 or 120,000 euros, you must make it effective by depositing it into account no. IBAN: ES00-0000-0000-0000-0000 (BIC/SWIFT Code: CAIXESBBXXX) opened in the name of the Spanish Agency for Data Protection at the banking entity CAIXABANK, S.A., indicating in the concept the reference number of the procedure that appears in the heading of this document and the reason for the reduction of the amount to which you are adhering.

You must also send the proof of deposit to the General Subdirectorate of Inspection to continue with the procedure in accordance with the amount deposited.

The procedure will have a maximum duration of twelve months from the date of the initiation agreement or, where applicable, from the draft initiation agreement. After this period, it will expire, and consequently, the file will be archived; in accordance with the provisions of Article 64 of the LOPDGDD.

In compliance with Articles 14, 41, and 43 of the LPACAP, it is warned that, henceforth, notifications sent to you will be carried out exclusively electronically by appearance at the electronic headquarters of the General Access Point of the Administration or through the single Enabled Electronic Address, and that, if you do not access them, your rejection will be recorded in the file, considering the procedure completed and continuing with the process. You are informed that you can identify an email address before this Agency to receive the notice of the availability of notifications and that the lack of practice of this notice will not prevent the notification from being considered fully valid.

Finally, it is noted that according to the provisions of Article 112.1 of the LPACAP, there is no administrative appeal against this act.

935-18032024

Mar España Martí

Director of the Spanish Agency for Data Protection

>>

SECOND: On June 4, 2024, the responding party proceeded to pay the sanction in the amount of 160,000 euros, making use of one of the two reductions provided for in the previously transcribed Initiation Agreement. Therefore, the acknowledgment of responsibility has not been accredited.

THIRD: The payment made entails the renunciation of any action or appeal in the administrative route against the sanction, in relation to the facts referred to in the Initiation Agreement.

FOURTH: The Initiation Agreement transcribed above indicated that it could be agreed to impose on the responsible party the adoption of appropriate measures to adjust their actions to the regulations mentioned in this act, in accordance with the provisions of the cited Article 58.2 d) of the GDPR, according to which each supervisory authority may "order the controller or processor to ensure that the processing operations are in compliance with the provisions of this Regulation, where appropriate, in a specific manner and within a specified time frame...".

LEGAL GROUNDS

I

Competence

In accordance with the powers granted by Article 58.2 of Regulation (EU) 2016/679 (General Data Protection Regulation, hereinafter GDPR), to each supervisory authority and as established in Articles 47, 48.1, 64.2, and 68.1 of Organic Law 3/2018, of December 5, on Personal Data Protection and the guarantee of digital rights (hereinafter, LOPDGDD), the Director of the Spanish Agency for Data Protection is competent to initiate and resolve this procedure.

Furthermore, Article 63.2 of the LOPDGDD states that: "The procedures processed by the Spanish Agency for Data Protection will be governed by the provisions of Regulation (EU) 2016/679, this organic law, by the regulatory provisions issued in its development and, as long as they do not contradict them, subsidiarily by the general rules on administrative procedures."

II

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

Termination of the Procedure

Article 85 of Law 39/2015, of October 1, on the Common Administrative Procedure of Public Administrations (hereinafter, LPACAP), under the heading "Termination in Sanctioning Procedures" provides as follows:

"1. Once a sanctioning procedure has been initiated, if the offender acknowledges their responsibility, the procedure may be resolved with the imposition of the appropriate sanction.

2. When the sanction is solely of a pecuniary nature or when it is possible to impose a pecuniary sanction and another of a non-pecuniary nature but the imposition of the latter has been justified as inappropriate, voluntary payment by the presumed responsible party, at any time prior to the resolution, will imply the termination of the procedure, except regarding the restoration of the altered situation or the determination of compensation for the damages caused by the commission of the infringement.

3. In both cases, when the sanction is solely of a pecuniary nature, the competent body to resolve the procedure will apply reductions of at least 20% on the amount of the proposed sanction, which may be cumulative. The aforementioned reductions must be specified in the notification of the initiation of the procedure, and their effectiveness will be conditioned upon the withdrawal or renunciation of any action or administrative appeal against the sanction. The percentage of reduction provided in this section may be increased by regulation."

Having proceeded with the payment of the pecuniary sanction, in accordance with section 2 of this article, voluntary payment implies the termination of the procedure, except regarding the restoration of the altered situation. Therefore, it is necessary to impose the measures required to cease the conduct or correct the effects of the infringement.

In accordance with the above, the Director of the Spanish Agency for Data Protection RESOLVES: FIRST: TO DECLARE the termination of procedure EXP202213514, in accordance with the provisions of Article 85 of the LPACAP.

SECOND: TO ORDER ALLIANZ COMPAÑÍA DE SEGUROS Y REASEGUROS, S.A. to notify the Agency within 3 months from the date this resolution becomes final and enforceable, of the adoption of the measures described in the legal grounds of the Agreement of initiation transcribed in this resolution.

THIRD: TO NOTIFY this resolution to ALLIANZ COMPAÑÍA DE SEGUROS Y REASEGUROS, S.A. In accordance with the provisions of Article 50 of the LOPDGDD, this Resolution will be made public once it has been notified to the interested parties.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

Against this resolution, which concludes the administrative procedure as provided by Article 114.1.c) of Law 39/2015, of October 1, on the Common Administrative Procedure of Public Administrations, the interested parties may file a contentious-administrative appeal before the Contentious-Administrative Chamber of the National Court, in accordance with the provisions of Article 25 and section 5 of the fourth additional provision of Law 29/1998, of July 13, regulating the Contentious-Administrative Jurisdiction, within a period of two months from the day following the notification of this act, as provided in Article 46.1 of the aforementioned Law.

1309-16012024

Mar España Martí

Director of the Spanish Agency for Data Protection

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

